

گزارش امنیت سازی NouraCare

این سند خلاصه کارهایی است که برای آماده سازی بک اند و کلاینت (قبل از انتشار در Google Play / App Store) انجام شده است.

خلاصه یک خطی

قبل از این تغییرات، ورود با ایمیل بدون اثبات هویت، API های سلامت بدون احراز هویت، و توکن های ناامن وجود داشت. الان: احراز هویت سراسری، ورود با کد ایمیل، توکن های امن، و محافظت از داده های کاربر پیاده شده است.

۱. تغییرات بک اند (NestJS — پوشه /server)

۱.۱ گارد JWT سراسری

- قبل: هر کنترلر خودش تصمیم می گرفت محافظت شود یا نه.
- بعد: تقریباً همه API ها نیاز به JWT دارند و route های عمومی با دکوراتور `@Public()` مشخص شده اند.

فایل های کلیدی:

```
/server - server/src/auth/guards/global-jwt-auth.guard.ts
/server/src - src/auth/decorators/public.decorator.ts
app.module.ts
```

Route های عمومی (بدون توکن): - ثبت نام، ورود (Email/Social)، Refresh، تایید ایمیل. - خواندن انجمن، لیست پزشکان و شهرها. - فرآیند Onboarding قبل از ثبت نام.

۱.۲ قفل کردن API های حساس (رفع IDOR)

قبلاً هر کسی با داشتن `userId` می توانست داده های دیگران را دستکاری کند. اکنون تمامی مسیرهای زیر با JWT و بررسی مالکیت (`assert-user-ownership`) محافظت

می‌شوند: - پروفایل کاربر (`*/profile/:id/`) - ثبت فعالیت‌های روزانه (`-track/`)
- مدیریت کاربر و آدرس‌ها (`*/day/:userId/` , `*/user/:id/` , `/geo/`)
- حذف حساب کاربری (`users/:id/addresses`) (`DELETE /user/me`)

۱.۳ ورود دو مرحله‌ای با ایمیل

فرآیند جدید: 1. مرحله ۱: ارسال ایمیل و دریافت کد ۶ رقمی. 2. مرحله ۲: تایید کد و دریافت توکن‌های دسترسی. شرط: کاربر باید قبلاً ایمیل خود را تایید کرده باشد (`isVerified: true`).

۱.۴ ورود با شبکه‌های اجتماعی (Google / Apple)

سرور اکنون توکن‌ها را مستقیماً با سرویس‌دهنده (Google/Apple) چک می‌کند و دیگر به ادعای کلاینت بسنده نمی‌کند. برای Apple، امضای JWT با کلید عمومی اپل بررسی می‌شود.

۱.۵ امنیت توکن‌ها (Refresh Token Rotation)

- فرمت جدید: توکن‌ها به صورت `{userId}.{uuid}` تغییر یافتند.
- چرخش (Rotation): با هر بار تمدید، توکن قدیمی باطل (Revoke) می‌شود.
- امنیت: هش کردن توکن‌ها در دیتابیس با `bcrypt` انجام می‌شود.

۱.۶ محدودیت درخواست (Rate Limiting)

محدودیت روی بخش‌های حساس: - ثبت‌نام: ۵ درخواست در دقیقه. - ورود و تایید: ۱۰ درخواست در دقیقه.

۲. تغییرات کلاینت (Angular — پوشه `/client`)

۲.۱ رابط کاربری جدید ورود

صفحه لاگین به صورت دو مرحله‌ای (دریافت ایمیل -> دریافت کد) بازطراحی شد.

۲.۲ مدیریت توکن‌ها

- ارسال `idToken` یا `accessToken` واقعی در ورود گوگل.
- ذخیره‌سازی امن `refreshToken` در حافظه محلی برای استفاده در `Interceptor` جهت تمدید خودکار.

۲.۳ حذف حساب و تنظیمات

امکان حذف کامل حساب کاربری از بخش تنظیمات اضافه شد که مستقیماً API حذف سرور را فراخوانی می‌کند.

۳. موارد باقی‌مانده قبل از انتشار نهایی

مورد وضعیت	اقدام لازم
❌ HTTPS روی API	تنظیم TLS روی Nginx یا Cloudflare
❌ محیط Production	تغییر آدرس API به <code>https</code> در <code>environment.prod.ts</code>
❌ تنظیمات محیطی	تکمیل فایل <code>env.</code> در سرور با کدهای امنیتی واقعی
⚠️ Apple Sign-In	اطمینان از ارسال <code>idToken</code> از Capacitor کلاینت
⚠️ CORS	محدود کردن دسترسی فقط به دامنه اصلی و اپ موبایل

۴. چک‌لیست تست نهایی

1. ثبت‌نام جدید و تایید ایمیل.
2. تست ورود دو مرحله‌ای.
3. تست ورود با گوگل.
4. تلاش برای دسترسی به دیتای کاربر دیگر (باید 403 بدهد).
5. تست انقضای توکن و Refresh خودکار.
6. حذف حساب کاربری.

آخرین به‌روزرسانی: ژوئن ۲۰۲۶